

# Cyber Tabletop Exercise

## Data Integrity Attack on AML and Sanctions Screening

Facilitation-ready improved version based on the uploaded scenario and evaluation feedback.

|                                                                                                                                 |                                                                              |
|---------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|
| <div>SCENARIO TITLE</div> <div>TTX Scenario 10 — Data integrity attack on AML and sanctions screening</div>                     | <div>SECTOR</div> <div>Financial services</div>                              |
| <div>PRIMARY AUDIENCE</div> <div>Executive, operational, technical, compliance, legal, and crisis-management stakeholders</div> | <div>RECOMMENDED DURATION</div> <div>90 minutes; expandable to 2 hours</div> |
| <div>VERSION</div> <div>Improved TTX v2.0</div>                                                                                 | <div>PREPARED DATE</div> <div>13 July 2026</div>                             |

# Contents

---

1. Improvement integration summary
2. Introduction
3. Exercise objectives
4. Scope
5. Intended participants and governance model
6. Exercise structure and rules of engagement
7. Assumptions and environment overview
8. Cyber threat pathway
9. Scenario narrative
10. Master timeline
11. Phased injects and facilitation guide
12. Decision points and authority matrix
13. Audience-specific discussion questions
14. Compensating controls and recovery criteria
15. Regulatory and communications considerations
16. Expected technical and business impacts
17. Facilitator guide and evaluation rubric
18. Debrief, lessons learned, and improvement actions
19. MITRE ATT&CK mapping
20. Source mapping and references
21. Ready-to-use opening script

# 1. Improvement Integration Summary

This version explicitly integrates the evaluation feedback. The source exercise had a strong financial-crime control-integrity storyline, but the assessment identified gaps in technical specificity, adversary lifecycle definition, ATT&CK integration, and formal evaluation criteria. The revised exercise keeps the original business arc and strengthens it into a cyber attack chain that is credible, evidence-driven, and facilitation-ready.

| Feedback area                     | Concrete improvement integrated                                                                                                                                                                                     |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Realism                           | Added concrete architecture: screening API, rules engine, watchlist/reference-data ingestion, case-management queues, payment channels, privileged roles, telemetry sources, and normal alert baselines.            |
| Cyber accuracy                    | Defined a complete adversary pathway from initial access through credential misuse, discovery, persistence, execution, defense impairment, data manipulation, limited collection/exfiltration, and business impact. |
| Coherence and evidence discipline | Each inject now separates confirmed facts, working assumptions, and unknowns, reducing ambiguity while preserving realistic uncertainty.                                                                            |
| Training value                    | Added audience-specific decision prompts, expected actions, success criteria, and observable behaviors for executive, operational, compliance, legal, SOC, and application teams.                                   |
| Structural completeness           | Added governance model, decision-authority matrix, regulatory trigger assumptions, evidence-preservation checklist, recovery criteria, and a formal scoring rubric.                                                 |

## 2. Introduction

This tabletop exercise simulates a cyber-related integrity failure affecting the bank’s AML and sanctions screening platform. The core challenge is not a visible outage. The platform appears available, transactions continue to flow, and technical health checks remain mostly green. However, the screening outcomes are no longer trustworthy: alerts collapse and selected transactions may be allowed without the expected sanctions and AML decisioning.

The exercise is designed to test whether participants can detect a silent but high-impact control failure, activate the appropriate cyber and crisis response structures, contain potential rule or reference-data manipulation, preserve evidence, manage payment and customer impact, communicate with regulators, and recover only after screening integrity is independently validated.

**Key exercise theme:** An available system can still be unsafe. Participants should focus on integrity, evidence, compensating controls, and defensible decisions under uncertainty.

## 3. Exercise Objectives

The objectives are to develop decision-making reflexes and improve coordination among business, compliance, technology, cyber, legal, and crisis-management teams. The exercise will test the organization’s ability to:

- **Recognize and validate silent control failure** in AML and sanctions screening when platform availability appears normal but alert outcomes are no longer trustworthy.

- **Classify the event accurately** as a cyber integrity incident, compliance-control failure, operational disruption, potential regulatory event, or combination of these.
- **Activate the correct governance model** by coordinating SOC, application support, compliance, payment operations, legal, communications, business continuity, executive leadership, and the crisis cell.
- **Make risk-based processing decisions** on whether to continue, queue, pause, manually review, or selectively fail-close transaction classes and payment corridors.
- **Preserve and interpret evidence** across IAM, PAM, SIEM, EDR, database audit, application logs, rule repositories, CI/CD deployment logs, and watchlist feed processing.
- **Reconstruct the impacted transaction population** and define a defensible retrospective screening, replay, exception review, and remediation approach.
- **Prepare regulator-ready communications** with known facts, unknowns, immediate controls, impact estimates, next-update cadence, and accountable owners.
- **Define safe recovery criteria** before normal processing resumes, including independent validation of rule integrity, watchlist currency, monitoring, and auditability.

### 3.1 Audience-specific objectives

#### Executive and crisis-management objectives

- Set an enterprise risk posture when a critical compliance control cannot be trusted.
- Approve business-impacting decisions such as selected payment pauses, regulator engagement, customer/correspondent messaging, and recovery acceptance.
- Maintain an accurate decision log and update cadence for board, group, and regulator stakeholders.

#### Operational and compliance objectives

- Define the affected transaction population and implement credible compensating controls.
- Prioritize manual screening and exception review based on sanctions, AML, customer, geography, and payment-risk criteria.
- Prepare regulator-ready facts, unknowns, actions, next updates, and remediation commitments.

#### Technical and cyber objectives

- Validate screening execution end-to-end and preserve logs, configurations, deployment artifacts, and privileged-access evidence.
- Identify the adversary pathway using IAM, PAM, EDR, SIEM, database, repository, and CI/CD telemetry.
- Restore known-good configuration and prove control integrity before normal processing resumes.

#### Legal, privacy, audit, and communications objectives

- Assess notification thresholds, privilege, disclosure obligations, and defensible evidence handling.
- Coordinate internal, external, customer, correspondent-bank, and supervisory messaging.
- Capture observations and convert them into auditable remediation actions.

## 4. Scope

### In scope

- AML and sanctions screening platform, screening API, matching engine, rules repository, watchlist/reference-data feeds, case-management workflow, and alert queues.
- Payment operations and transaction flows for SWIFT, wire, ACH, SEPA/local clearing, high-value payments, correspondent-bank activity, and high-risk customer segments.
- Compliance operations, financial crime, sanctions advisory, fraud, legal, privacy, communications, internal audit, and crisis management.
- Security operations, incident response, application support, infrastructure, database administration, IAM, PAM, DevOps/CI-CD, logging, monitoring, and data integrity teams.
- Regulatory notification decision-making and post-incident reporting assumptions.

### Out of scope

- Hands-on exploitation, malware development, password cracking, or technical implementation of attack tools.
- Detailed forensic malware reverse engineering.
- Vendor contract negotiation or procurement decisions.
- Final legal advice on jurisdiction-specific regulatory notification thresholds.
- Production restoration runbooks at command or implementation level.

## 5. Intended Participants and Governance Model

The exercise is designed for cross-functional response. Participants should respond according to existing roles, responsibilities, authorities, and procedures. Where the organization's actual governance differs, the facilitator should ask participants to identify the real decision owner and escalation route.

| Function                              | Primary responsibilities during the exercise                                                                                        | Decisions to make or recommend                                                                              |
|---------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Executive / Crisis Cell               | Set risk appetite, approve business-impacting decisions, maintain governance cadence, escalate to board or group crisis structures. | Pause/queue scope; customer/correspondent messaging; board/regulator engagement posture; recovery approval. |
| Compliance / MLRO / Sanctions Officer | Assess control failure, impacted population, sanctions/AML exposure, compensating controls, and retrospective review approach.      | Materiality; lookback window; acceptable manual controls; regulator facts and commitments.                  |
| Legal / Privacy                       | Preserve privilege where appropriate, advise on notifications, evidence handling, contractual obligations, and disclosure risk.     | Notification threshold; record preservation; customer/counterparty disclosure; privilege strategy.          |
| Payment Operations                    | Identify payment rails, queues, high-risk corridors, workarounds, backlog, and operational constraints.                             | Which transactions continue; which are held; prioritization rules; manual-review capacity.                  |

| Function                                | Primary responsibilities during the exercise                                                                                                           | Decisions to make or recommend                                                                                 |
|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| SOC / Cyber IR                          | Lead technical triage, evidence preservation, account containment, telemetry analysis, threat hunting, and technical isolation/reconnection decisions. | Disable accounts/tokens; isolate admin workstations; preserve images/logs; recommend severity and containment. |
| Application Owner / IT Support          | Validate screening execution, restore known-good configuration, coordinate vendor/application support, and perform control testing.                    | Rollback; restoration order; service dependencies; safe reconnection and monitoring criteria.                  |
| IAM / PAM / DevOps / DBA                | Review privileged access, service accounts, secrets, deployment pipelines, database activity, and unauthorized change paths.                           | Credential rotation; emergency access; configuration freeze; deployment rollback; audit completeness.          |
| Communications / Stakeholder Management | Coordinate internal messaging, regulator-ready language, customer/counterparty holding statements, and staff instructions.                             | Message timing, audience, level of transparency, and approval route.                                           |
| Internal Audit / Risk                   | Observe decision quality, capture control gaps, validate post-incident actions and remediation commitments.                                            | After-action owners, due dates, and control assurance expectations.                                            |

**Governance principle:** The SOC leads technical containment and evidence preservation. The Crisis Cell does not direct forensic steps but receives SOC recommendations and approves enterprise-risk decisions, including business-impacting pauses, external messaging, and return-to-normal acceptance.

## 6. Exercise Structure and Rules of Engagement

### Structure

- **Recommended duration:** 90 minutes; use the extended questions for a 2-hour session.
- **Format:** facilitated discussion-based tabletop exercise.
- **Delivery model:** sequential injects followed by debrief questions.
- **Timeline convention:** relative time beginning at discovery, with pre-incident backstory disclosed later.
- **Assumption:** participants use existing procedures and identify gaps where procedures are unclear.

### Rules of engagement

- Real-world incidents take priority.
- There are no right or wrong answers; the purpose is to surface strengths, gaps, and decision quality.
- Participants should respond as if the incident were real.
- The scenario is designed to test processes and coordination, not to criticize a team, vendor, or system owner.
- Do not fight the scenario; state assumptions and proceed with realistic decisions.
- Avoid sharing sensitive production details beyond what is necessary for the exercise.

## 6.1 Suggested agenda

| Time      | Activity                                                           |
|-----------|--------------------------------------------------------------------|
| 0–10 min  | Welcome, rules, objectives, participant roles, and opening script. |
| 10–20 min | Inject 1: abnormal alert collapse.                                 |
| 20–35 min | Inject 2: fail-open validation.                                    |
| 35–50 min | Inject 3: privileged access anomaly and containment.               |
| 50–65 min | Inject 4: lookback, high-risk transaction, and regulator pressure. |
| 65–78 min | Inject 5: root-cause evidence and telemetry gap.                   |
| 78–88 min | Inject 6: recovery and post-incident obligations.                  |
| 88–90 min | Wrap-up, observation capture, and after-action ownership.          |

## 7. Assumptions and Environment Overview

The scenario deliberately enriches the original STIX-derived input with realistic environmental assumptions. Facilitators should tailor names, rails, geographies, regulators, and thresholds to the organization before delivery.

**Core assumption:** The bank’s AML and sanctions screening platform is a critical compliance control. It is integrated with payment flows and must produce auditable decisions of allow, queue, block, or review.

| Component                           | Exercise assumption                                                                                                                                                                   |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Payment channels                    | SWIFT MT/MX, Fedwire/local wire, ACH, SEPA/local clearing, internal book transfers, and selected treasury/correspondent flows.                                                        |
| Screening API                       | Receives payment and customer-screening requests from upstream systems and returns allow, queue, block, or review responses.                                                          |
| Rules and matching engine           | Applies sanctions, politically exposed persons, adverse media, geographic, typology, and internal interdiction rules.                                                                 |
| Watchlist/reference-data ingestion  | Consumes vendor sanctions lists, internal lists, country/currency risk tables, threshold tables, and delta updates on scheduled cadence.                                              |
| Case management                     | Creates alerts, queues exceptions, records analyst decisions, and retains an auditable outcome trail.                                                                                 |
| Rule repository and deployment path | Rules and configuration packages are version-controlled and deployed through a controlled pipeline with approvals and hash validation.                                                |
| Telemetry and control assurance     | SIEM, EDR, PAM session logs, IAM sign-in logs, database audit logs, API gateway logs, CI/CD logs, file-integrity monitoring, synthetic test transactions, and alert-volume baselines. |
| Privileged roles                    | Compliance Rules Administrator, Application Administrator, Data Operations Engineer, Database Administrator, DevOps Release Engineer, PAM Emergency Access Approver.                  |

## 7.1 Normal operating baseline

|                                                                                                                                                      |                                                                                                                                                                       |                                                                                                                                                                |
|------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Transaction baseline</b><br>Approximately 100,000–200,000 screened events per business day, with periodic intraday peaks around payment cut-offs. | <b>Alert baseline</b><br>Typical sanctions/AML alert rates vary by channel and customer mix, but a sustained zero-alert period during normal throughput is anomalous. | <b>Change baseline</b><br>Rules and watchlist mapping changes require approved change tickets, dual approval, deployment evidence, and post-change validation. |
|------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|

## 7.2 Critical control dependencies

- MFA and conditional access for administrative portals, VPN, VDI, cloud consoles, and privileged sessions.
- PAM brokered access with session recording for rule changes, database changes, and emergency access.
- Four-eyes approval for production rules, watchlist feed mapping, scoring threshold changes, and deployment rollback.
- Independent rule-hash attestation and watchlist delta reconciliation against a last-known-good baseline.
- Synthetic screening tests with known control cases to detect fail-open or suppression behavior.
- SIEM correlation for alert-volume collapse, anomalous administrative access, configuration drift, and sudden suppression of expected telemetry.
- Legal hold and evidence preservation for logs, deployment artifacts, administrative workstation images, and decision records.

# 8. Cyber Threat Pathway

The revised scenario defines an explicit adversary pathway while preserving uncertainty during early injects. The facilitator should disclose evidence in stages. Participants should not receive the complete attack chain at the start.

|                                                             |                                                |                                                       |                                                         |                                                          |
|-------------------------------------------------------------|------------------------------------------------|-------------------------------------------------------|---------------------------------------------------------|----------------------------------------------------------|
| <b>Initial access</b><br>Credential capture / valid account | <b>Discovery</b><br>Admin groups, rules, repos | <b>Persistence</b><br>Role or credential manipulation | <b>Execution</b><br>Admin tooling / deployment workflow | <b>Evasion</b><br>Telemetry or integrity checks impaired |
| <b>Impact</b><br>Rules/data altered; screening fails open   |                                                |                                                       | <b>Response</b><br>Lookback, containment, recovery      |                                                          |

| Stage             | Scenario behavior                                                                                                                                                                                                                                    | Observable evidence                                                                                             |
|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|
| 1. Initial access | A targeted spearphishing link captures credentials and session context for a compliance rules administrator or vendor-support account. The adversary later authenticates through VPN/VDI or an external administrative portal using a valid account. | Unusual MFA prompt history, impossible travel, new device fingerprint, access outside normal working hours.     |
| 2. Discovery      | The adversary enumerates screening-admin groups, code/config repositories, PAM vault metadata, rule packages, service accounts, and watchlist ingestion jobs.                                                                                        | Queries against IAM groups, repository access to screening documentation, PAM search activity, API enumeration. |



| Stage                                   | Scenario behavior                                                                                                                                                                                                                 | Observable evidence                                                                                                                      |
|-----------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| 3. Persistence and privilege expansion  | A temporary role assignment, additional cloud credential, service-account token, or emergency access exception is created to preserve access without immediately disabling service availability.                                  | New API key/secret, unusual emergency access request, role assignment outside normal change window.                                      |
| 4. Execution                            | The adversary uses approved administrative tooling, scripts, or deployment workflow to stage a configuration package that changes screening decision behavior.                                                                    | CI/CD job triggered from unusual source, unplanned deployment, admin scripts executed against screening configuration.                   |
| 5. Defense evasion / defense impairment | Telemetry thresholds are narrowed, integrity-check jobs are delayed, or log forwarding is partially impaired to reduce the chance that configuration drift is detected immediately.                                               | Gap in application audit stream, integrity monitor heartbeat missing, detection rule changed without ticket.                             |
| 6. Data manipulation / impact           | A rule or reference-data mapping causes selected screening errors to return an allow response, suppresses alert generation for selected rule categories, or changes matching thresholds so some high-risk transactions fail open. | Hash mismatch, synthetic test cases return allow instead of queue/block, alert volumes collapse while transaction volume remains normal. |
| 7. Collection / limited exfiltration    | The adversary collects configuration exports, rule metadata, and operational summaries to confirm the manipulation. No customer data exfiltration is assumed unless introduced by the facilitator.                                | Outbound web traffic from admin host, compressed configuration exports, repository downloads.                                            |
| 8. Business and compliance impact       | Transactions may have proceeded without expected screening; the organization must determine whether to pause flows, apply compensating controls, notify regulators, and perform retrospective screening.                          | Payment backlog, regulator/ correspondent questions, lookback uncertainty, executive pressure for recovery.                              |

**Facilitator note:** Avoid providing command-level details. The purpose is to test threat-informed response and control assurance, not to teach offensive tradecraft.

## 9. Scenario Narrative

During a normal business period with expected transaction throughput, Compliance Operations notices that sanctions and AML alert volumes have unexpectedly dropped to zero or near zero. Initial technology checks show that the application is online. Payment systems continue receiving screening responses, so the business initially assumes the platform is available.

Further validation shows that known-match test cases are returning allow responses rather than queue or block decisions. The organization must determine whether the issue is a monitoring failure, watchlist feed error, unauthorized change, privileged misuse, malicious tampering, or some combination. As evidence develops, SOC identifies suspicious privileged activity and a configuration drift that overlaps with the alert collapse.

The bank now faces an enterprise decision: whether to pause or queue payment classes, how to apply compensating controls, how to reconstruct the affected transaction population, when to notify regulators, how to message correspondents and customers, and what evidence is necessary before normal processing can resume.

## 10. Master Timeline

The timeline below includes both facilitator backstory and participant-facing injects. Early backstory should be disclosed only when appropriate.

| Time              | Event                                                                                                                                       | Disclosure guidance                                             |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| T-5 days          | Targeted credential capture begins.                                                                                                         | Not disclosed initially; available to facilitator as backstory. |
| T-2 days          | Compromised valid account accesses screening documentation, admin groups, and deployment metadata.                                          | Disclosed in Inject 3 or later.                                 |
| T-12 hours        | Unauthorized rule/configuration package is staged outside the normal change window.                                                         | Disclosed in Inject 3.                                          |
| T+0               | Compliance operations notices AML and sanctions alert volume collapse while transaction volume remains normal.                              | Inject 1.                                                       |
| T+45 minutes      | Synthetic screening tests and sample transactions indicate fail-open behavior; dashboard-only issue is unlikely.                            | Inject 2.                                                       |
| T+2 hours         | SOC identifies unusual privileged access and configuration hash mismatch; leadership must decide on containment and payment processing.     | Inject 3.                                                       |
| T+4 hours         | High-risk transaction and regulator/correspondent inquiry increase urgency; lookback completeness is uncertain.                             | Inject 4.                                                       |
| T+1 business day  | Technical review confirms tampered rules/reference mapping and gaps in telemetry; root cause and persistence are still under investigation. | Inject 5.                                                       |
| T+2 business days | Known-good configuration is restored, retrospective screening is underway, and post-incident reporting/recovery approval is required.       | Inject 6.                                                       |

## 11. Phased Injects and Facilitation Guide

### Inject 1 — Abnormal AML and sanctions alert volume collapse

**T+0** **Purpose:** Force participants to distinguish system availability from control integrity.

**Compliance Operations notices that sanctions and AML alerts have dropped to zero or near zero during a period of normal transaction throughput. No approved maintenance window or rule change is known.**

#### What participants know at this stage

- Payment volume is within expected daily range.
- The case-management queue is unusually quiet across sanctions and AML workflows.
- The platform health dashboard shows green status for API availability and database availability.
- No business team has requested a sanctions or AML rule change in the last 24 hours.
- It is not yet known whether this is a dashboard issue, rule issue, data-feed problem, operational error, or cyber incident.

#### Evidence / assumptions / unknowns

- Confirmed: alert-volume collapse and normal transaction throughput.
- Confirmed: no approved maintenance window.
- Unknown: whether transactions were actually screened.
- Unknown: whether a cyber actor is involved.

#### Facilitator prompts

- Who validates whether screening is executing end-to-end, not merely whether the application is online?
- What baselines determine whether zero alerts is anomalous for the current payment mix?
- Who opens the incident record and which severity criteria apply before root cause is known?
- What immediate data, logs, and configuration snapshots must be preserved?
- Which high-risk transaction categories should receive immediate compensating controls?

#### Expected actions

- Open an incident and start a decision log.
- Run synthetic sanctions/AML test transactions through production-like paths where policy permits.
- Compare alert rates with transaction volumes, payment types, corridors, customer risk tiers, and historical baselines.
- Snapshot rule versions, watchlist versions, configuration hashes, application logs, and database audit records.
- Notify Compliance, SOC, application support, Payment Operations, Legal, and the crisis-management lead that a critical control may be unreliable.

#### Facilitator notes

Push participants away from “the system is green” reasoning. The key test is whether control outcomes are trustworthy.

#### Success criteria

Participants escalate within the first inject, validate control outcomes independently, and preserve evidence before attempting changes.

#### ATT&CK cues

Primary ATT&CK cue: Impact / Data Manipulation (T1565) is suspected but not confirmed.

## Inject 2 — End-to-end validation indicates fail-open screening behavior

**T+45 minutes** Purpose: Move from anomaly to credible control failure while retaining uncertainty about cause.

**Application support and Compliance run controlled test cases. Several known-match test cases return an allow response instead of queue/block. Watchlist ingestion status is green, but the rules engine appears to be bypassing selected categories.**

### What participants know at this stage

- Synthetic test transactions that normally create alerts are not generating alerts.
- Upstream payment systems are still receiving allow responses.
- The latest watchlist file arrived on schedule, but a mapping table may not have loaded correctly.
- A scheduled integrity-monitoring job did not report its latest heartbeat.
- Payment Operations asks whether high-value and cross-border payment classes can continue.

### Evidence / assumptions / unknowns

- Confirmed: selected control test cases are failing.
- Confirmed: business flow continues despite failed screening outcomes.
- Working assumption: control integrity is impaired.
- Unknown: malicious tampering, privileged error, defective release, or data corruption.

### Facilitator prompts

- What is the threshold to classify the issue as a cyber integrity incident and compliance-control failure?
- Should the bank fail-close all affected flows, only high-risk flows, or apply manual review?
- Who has authority to pause payments, and who must be consulted before doing so?
- What evidence is needed to define the start time and impacted transaction population?
- What is the first regulator-ready fact pattern?

### Expected actions

- Declare a material control-integrity incident under internal severity criteria.
- Freeze non-essential changes to the screening platform and related deployment pipelines.
- Apply risk-based compensating controls: hold high-risk jurisdictions, high-value wires, sanctions-sensitive corridors, and transactions involving high-risk customers.
- Begin impacted-population scoping using transaction timestamps, payment rails, customer risk ratings, screening response codes, and rule versions.
- Prepare a short fact/unknowns/action/update-cadence briefing for senior leaders and Legal/Compliance.

### Facilitator notes

Do not let participants debate whether one failed test is enough. The issue is that confidence in a key compliance control has been lost.

|                         |                                                                                                                                   |
|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| <b>Success criteria</b> | Participants define a containment posture and affected-scope methodology, even though root cause remains unresolved.              |
| <b>ATT&amp;CK cues</b>  | ATT&CK cues: Stored Data Manipulation (T1565.001) and potential defense impairment if the integrity monitor heartbeat is missing. |

## Inject 3 — Privileged access anomaly and business decision pressure

**T+2 hours** **Purpose:** Introduce the cyber pathway and force coordinated business, technical, and compliance decisions.

**SOC correlates IAM, PAM, and deployment logs. A privileged account associated with screening rule administration accessed the rule repository and triggered a configuration deployment outside the normal change window. The account owner states they did not perform the activity.**

### What participants know at this stage

- The privileged account used valid credentials and MFA.
- Access originated from an unusual device fingerprint and network location.
- A production configuration hash differs from the approved baseline.
- PAM session recording is incomplete for part of the activity.
- Payment Operations reports growing backlog where high-risk flows were manually held.

### Evidence / assumptions / unknowns

- Confirmed: suspicious privileged access and unapproved configuration drift.
- Confirmed: configuration drift overlaps with alert-volume collapse.
- Working assumption: likely compromised or misused privileged account.
- Unknown: how credentials were obtained and whether persistence remains.

### Facilitator prompts

- What immediate containment actions can SOC/IAM take without waiting for crisis-cell approval?
- How do you preserve forensic value while restoring a known-good configuration?
- Which payment classes remain stopped, which are manually reviewed, and which can continue?
- Does this meet criteria for notifying regulators or supervisory contacts now?
- What does the first executive briefing say about business impact and customer/counterparty impact?

### Expected actions

- Disable or suspend the suspect privileged account and revoke active sessions, tokens, API keys, and emergency-access grants.
- Isolate the account owner's administrative workstation for forensic preservation if feasible.
- Rotate credentials for related service accounts and validate that no unauthorized role assignments persist.
- Compare production rules, watchlist mappings, thresholds, and error-handling behavior against last-known-good baseline.
- Escalate to Crisis Cell with a clear recommendation: payment-processing posture,

regulator communications, evidence plan, and next update time.

- Document who approved any business-impacting hold, queue, fail-close, or manual-review approach.

|                          |                                                                                                                                                                                                     |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Facilitator notes</b> | SOC should own technical containment and evidence preservation. The Crisis Cell should own enterprise risk decisions, including broad payment pauses and external messaging.                        |
| <b>Success criteria</b>  | Participants contain privileged access rapidly, maintain evidence, and align business decisions with compliance risk.                                                                               |
| <b>ATT&amp;CK cues</b>   | ATT&CK cues: Valid Accounts (T1078), External Remote Services (T1133), Account Discovery (T1087), Permission Groups Discovery (T1069), Account Manipulation (T1098), and Data Manipulation (T1565). |

## Inject 4 — Lookback, high-risk transaction, and supervisory pressure

**T+4 hours** Purpose: Test risk-based decision-making, notification logic, and completeness of retrospective screening.

**A high-value cross-border transaction processed during the suspected exposure window involves a sanctioned-region nexus and was released without an alert. A correspondent bank asks whether screening controls are functioning normally. Compliance receives informal supervisory outreach requesting an update.**

### What participants know at this stage

- Exposure window is currently estimated at 11 to 14 hours but may expand.
- The transaction population includes cross-border wires, trade-finance payments, and internal transfers.
- Manual screening capacity can handle only a fraction of daily volume.
- The correspondent bank is asking for assurance but has not alleged a breach.
- Legal asks whether a regulator notification should be sent before root cause is fully known.

### Evidence / assumptions / unknowns

- Confirmed: at least one high-risk transaction was released during the exposure window.
- Confirmed: the affected population is not yet complete.

### Facilitator prompts

- What is the minimum fact pattern required before notification, and what can be said while preserving accuracy?
- How will the organization prove completeness of the lookback?
- Which transactions receive priority manual screening and why?
- How are correspondent-bank and customer-facing teams instructed to respond?
- What business disruption is acceptable to preserve compliance integrity?

### Expected actions

- Define lookback scope using earliest anomalous access, latest verified-good configuration, alert-volume baseline, and all transactions that received allow responses during the window.

- Working assumption: regulator engagement is likely required under internal escalation criteria.
- Unknown: whether any prohibited transaction was completed.
- Prioritize retrospective screening by sanctions-risk nexus, high-value wires, high-risk customers, high-risk geographies, and correspondent-bank exposure.
- Issue internal holding lines for customer-facing and correspondent-facing teams.
- Prepare regulator notification or supervisory update with known facts, unknowns, immediate controls, initial impact estimate, next update time, and responsible executive.
- Approve temporary staffing, extended hours, or external support for manual screening and exception review.

|                          |                                                                                                                                                                     |
|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Facilitator notes</b> | Push the group to avoid binary choices. A credible approach may combine selected pauses, fail-closed rules, manual review, and staged replay.                       |
| <b>Success criteria</b>  | Participants create a defensible notification and lookback plan without waiting for perfect information.                                                            |
| <b>ATT&amp;CK cues</b>   | ATT&CK cues: Impact / Stored Data Manipulation (T1565.001); possible Exfiltration Over C2 Channel (T1041) only if configuration export evidence is later confirmed. |

## Inject 5 — Root-cause uncertainty deepens: tampered rule package and telemetry gap

**T+1 business day** **Purpose:** Strengthen cyber accuracy and test technical/compliance collaboration under uncertain root cause.

**Technical review confirms that a production rule package and a watchlist mapping table were altered. The error-handling setting caused selected screening errors to return allow responses. SOC also finds evidence of suspicious repository access, a temporary role assignment, and partial impairment of monitoring jobs.**

### What participants know at this stage

- The altered package was deployed outside the normal change window.
- A temporary privileged role existed for approximately six hours and has now been removed.
- Some application audit logs are delayed or incomplete, but database audit logs and API gateway logs remain available.

### Facilitator prompts

- What evidence is sufficient to state that the incident is cyber-related?
- What additional hunting is required to rule out persistence or lateral movement?
- How do you decide whether to restore from last-known-good, rebuild, or keep the platform in restricted mode?
- How do Compliance and SOC jointly validate that restored rules produce correct outcomes?

- A limited configuration export may have left the environment over HTTPS.
- Manual screening backlog is causing delays in priority payments.

### Evidence / assumptions / unknowns

- Confirmed: stored configuration/rule data was altered.
- Confirmed: monitoring or logging was impaired, creating an evidence gap.
- Confirmed: privilege expansion occurred.
- Unknown: whether adversary access is fully eradicated and whether the exported data included customer information.

- How are backlog and customer-impact decisions approved and documented?

### Expected actions

- Preserve deployment packages, repository logs, PAM recordings, IAM events, admin workstation images, database audit records, and SIEM alerts.
- Hunt for related activity: account enumeration, role assignments, token creation, repository access, unusual outbound web traffic, and additional configuration drift.
- Restore known-good rules and watchlist mappings in a controlled environment before production.
- Run independent validation using synthetic sanctions/AML cases, historical cases, and sample production transactions.
- Maintain high-risk transaction holds until Compliance confirms screening assurance or manual-review criteria.
- Update regulator/supervisory stakeholders with root-cause status, remediation steps, impact estimate, and next milestone.

|                          |                                                                                                                                                                                                                                                                                                                                                              |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Facilitator notes</b> | The exercise should not become a forensic deep dive. Keep focus on executive-quality evidence, control assurance, and decision rights.                                                                                                                                                                                                                       |
| <b>Success criteria</b>  | Participants link technical facts to compliance impact and resist declaring recovery based only on a rollback.                                                                                                                                                                                                                                               |
| <b>ATT&amp;CK cues</b>   | ATT&CK cues: Account Manipulation (T1098), Command and Scripting Interpreter (T1059), Data from Information Repositories (T1213), Disable or Modify Tools / Impair Defenses (T1685/T1562), Indicator Removal (T1070), Application Layer Protocol: Web Protocols (T1071.001), Exfiltration Over C2 Channel (T1041), and Stored Data Manipulation (T1565.001). |

## Inject 6 — Recovery, retrospective screening, and post-incident obligations

**T+2 business days** Purpose: Test recovery approval, regulatory reporting, and after-action discipline.

The platform has been restored from a known-good configuration and independent testing shows expected screening outcomes. Retrospective screening identifies a subset of



transactions requiring escalated review. Regulators expect a written update covering root cause, impact, containment, remediation, and future control improvements.

### What participants know at this stage

- Synthetic and historical test cases now produce expected queue/block/review outcomes.
- All known suspicious privileged access has been revoked; related credentials have been rotated.
- Some retrospective screening remains in progress.
- A small number of transactions require sanctions advisory and financial-crime escalation.
- Executives want to resume normal processing and close the crisis cadence.

### Evidence / assumptions / unknowns

- Confirmed: restored configuration passes initial independent tests.
- Confirmed: lookback has identified exceptions for escalated review.
- Working assumption: normal processing can resume only after documented acceptance of residual risk.
- Unknown: final regulatory response and any enforcement implications.

### Facilitator prompts

- What evidence is required to declare safe recovery?
- Who approves return to normal and what residual risks are accepted?
- What remains on the regulator, board, and internal-audit action list?
- How will the organization monitor for recurrence over the next 30 days?
- What control improvements are mandatory before the exercise is considered closed?

### Expected actions

- Obtain formal signoff from SOC, Application Owner, Compliance, Payment Operations, Legal, and Crisis Cell authority before full resumption.
- Complete retrospective screening, exception review, suspicious-activity/sanctions analysis, and remediation tracking.
- Prepare post-incident report with timeline, root cause, impact, evidence limitations, decisions, notification actions, recovery validation, and improvement commitments.
- Implement heightened monitoring for alert volumes, rule hashes, watchlist deltas, privileged access, deployment activity, and synthetic screening failures.
- Transition from crisis cadence to remediation governance with owners, due dates, control testing, and internal-audit tracking.

### Facilitator notes

Recovery is not merely technical restoration. It requires confidence in control integrity, regulatory defensibility, and complete decision records.

### Success criteria

Participants define measurable recovery criteria and a credible after-action plan.

### ATT&CK cues

ATT&CK mapping is finalized and linked to evidence, not appended as a generic note.

## 12. Decision Points and Authority Matrix

Throughout the exercise, participants should explicitly state who has authority, who recommends, who must be consulted, and how decisions are recorded. The table below is a facilitation baseline and should be tailored to the organization.

| Decision                    | Recommended authority model                                                                                                                           | Trigger                                                                         |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| Classify incident severity  | SOC recommends cyber severity; Compliance assesses control severity; Crisis Cell confirms enterprise severity.                                        | Within first 60 minutes after evidence of fail-open behavior.                   |
| Contain privileged access   | SOC/IAM/PAM can disable suspected accounts, revoke tokens, isolate admin hosts, and freeze emergency access without waiting for crisis-cell approval. | Immediately when suspicious privileged activity is identified.                  |
| Pause or queue transactions | Compliance and Payment Operations recommend; Crisis Cell or delegated business authority approves broad business-impacting pause.                     | When screening assurance is unavailable for material flows.                     |
| Notify regulators           | Compliance and Legal recommend based on jurisdiction, materiality, and known facts; accountable executive approves where required by policy.          | Once thresholds are met or supervisory expectation requires early notification. |
| Resume standard processing  | Application Owner, SOC, Compliance, and Payment Operations provide evidence; Crisis Cell approves full return to normal.                              | Only after recovery criteria are met and residual risk accepted.                |
| Post-incident commitments   | Risk/Internal Audit track remediation owners; Compliance/Legal align reporting commitments.                                                           | During final inject and after-action process.                                   |

### 12.1 Core decision points

1. Is this an operational anomaly, a cyber integrity incident, a compliance-control failure, potential regulatory event, or all of these?
2. Which payment classes continue, queue, fail-close, or stop entirely?
3. What compensating controls are acceptable while root cause is under investigation?
4. What is the lookback window, and how will completeness of affected transactions be proven?
5. When should Legal and Compliance formally notify regulators or supervisors?
6. What evidence defines safe recovery and normal processing resumption?
7. How are decisions documented for auditability, legal defensibility, and supervisory review?
8. What is the internal and external communication posture while facts remain incomplete?

## 13. Audience-Specific Discussion Questions

### Executive / crisis management

- What is the current enterprise risk posture and worst credible outcome?
- Which decisions require executive approval now?

### Compliance / legal

- Does the event meet internal or external notification thresholds?
- What facts must be preserved for defensibility?

- What operational disruption is acceptable to preserve compliance integrity?
- What should be communicated to the board or group crisis structure?
- When is it safe to move from crisis cadence to remediation governance?

- How will the bank demonstrate completeness of retrospective screening?
- Which transactions require sanctions advisory or suspicious-activity escalation?
- What disclosures may be needed to customers, correspondents, regulators, or auditors?

### Operations / business

- Which payment rails, geographies, products, and customers are highest risk?
- What manual workarounds exist, and where do they create new risk?
- How will backlogs, cut-off times, customer commitments, and correspondent expectations be managed?
- How are exceptions approved and documented?

### Technical / cyber

- What evidence supports rule tampering, data corruption, privileged misuse, or defective deployment?
- What telemetry is trustworthy and what telemetry may be impaired?
- How is integrity of rules, watchlists, mappings, and screening outcomes independently verified?
- What recovery steps are required before reconnecting, replaying, or resuming full automation?

## 14. Compensating Controls and Recovery Criteria

### 14.1 Compensating controls during uncertainty

| Control option               | When to use                                                                                                         | Key risk or limitation                                                         |
|------------------------------|---------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Fail-close selected flows    | High-risk corridors, sanctions-sensitive geographies, high-value wires, or flows with unreliable screening results. | Creates backlog and customer/counterparty impact; must be approved and logged. |
| Queue and manual review      | Where volume is manageable and risk-based triage is possible.                                                       | Manual capacity may be insufficient; quality assurance must be defined.        |
| Independent screening replay | Retrospective review of transactions processed during exposure window.                                              | Requires complete transaction population and reliable historical input data.   |
| Dual approval for exceptions | Urgent or critical payments that cannot wait for full automation recovery.                                          | Exception pressure can weaken controls unless criteria are strict.             |
| Rule rollback to known-good  | When configuration tampering is confirmed and a validated baseline exists.                                          | Rollback alone does not prove eradication or monitoring integrity.             |
| Heightened monitoring        | During containment and recovery.                                                                                    | Only useful if telemetry pathways are verified as complete and trustworthy.    |

## 14.2 Safe recovery criteria

- Known-good rules, watchlist mappings, scoring thresholds, and error-handling behavior are restored and hash-verified.
- Synthetic sanctions/AML test cases and sampled historical cases produce expected decisions across relevant payment rails.
- Suspect accounts, sessions, tokens, service credentials, emergency access grants, and role assignments are revoked or rotated.
- SIEM, application audit, database audit, PAM, API gateway, and integrity-monitoring telemetry are confirmed complete enough for recovery assurance.
- Retrospective screening methodology is approved by Compliance and Legal, with clear handling of exceptions and incomplete data.
- Payment Operations has a backlog plan, customer/correspondent messaging, and cut-off management approach.
- Regulatory updates are prepared or submitted according to the agreed notification strategy.
- Crisis Cell formally accepts residual risk and documents the recovery decision.

## 15. Regulatory and Communications Considerations

This section provides exercise assumptions only. Actual notification obligations depend on entity type, jurisdiction, licensing, contracts, regulators, materiality, and local legal advice.

| Jurisdiction / regulator                 | Exercise notification assumption                                                                                                                                                                                                                      | Facilitation use                                                                                                                       |
|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Canada / OSFI                            | Exercise assumption for federally regulated financial institutions: report technology or cyber security incidents within 24 hours, or sooner if possible, when reporting criteria are met.                                                            | Use Legal/Compliance to confirm applicability, entity scope, and whether silent AML/sanctions control failure meets internal criteria. |
| United States / Federal banking agencies | Exercise assumption: notify the primary federal regulator as soon as possible and no later than 36 hours after determining that a notification incident occurred.                                                                                     | Material disruption or degradation of banking operations, services, or critical business lines should drive analysis.                  |
| European Union / DORA                    | Exercise assumption: major ICT-related incident reporting timelines include initial notification within 4 hours after classification and within 24 hours after detection, intermediate reporting around 72 hours, and final reporting around 1 month. | Apply only if the entity and incident fall within DORA scope and classification criteria.                                              |
| United Kingdom / FCA/PRA                 | Exercise assumption: material operational/cyber incidents require timely regulatory engagement; new FCA incident reporting rules are scheduled to come into force on 18 March 2027.                                                                   | Confirm current rule set and prudential/conduct notification route with Legal/Compliance.                                              |

### 15.1 Regulator-ready fact pattern template

**Recommended structure:** incident summary; date/time detected; systems and control processes affected; current business impact; known and suspected cyber indicators; transactions potentially affected; immediate

containment actions; compensating controls; customer/correspondent impact; current unknowns; next-update timing; accountable executive; remediation commitments.

## 15.2 Internal and external communications

| Audience                             | Message objective                                                                                         | Approver                                          |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------|---------------------------------------------------|
| Executive leadership / board         | Decision-quality summary of risk posture, business impact, regulatory exposure, and decisions required.   | Crisis lead, Compliance, Legal, CISO.             |
| Payment and customer-facing teams    | Operational instructions, approved holding lines, escalation route, and exception handling.               | Payment Ops, Communications, Legal.               |
| Regulators / supervisors             | Known facts, immediate actions, impact estimate, notification basis, and next-update cadence.             | Compliance, Legal, accountable executive.         |
| Correspondent banks / counterparties | Assurance-oriented message that avoids overstatement while explaining delays or requests for information. | Business lead, Compliance, Legal, Communications. |
| Employees                            | Need-to-know message reinforcing reporting channels and caution against speculation.                      | Communications, HR, Legal.                        |

## 16. Expected Technical and Business Impacts

### Technical impacts

- Loss of confidence in screening outcomes despite platform availability.
- Unauthorized modification of rules, watchlist mappings, thresholds, or error handling.
- Potential gaps in application audit logs, integrity monitors, or telemetry forwarding.
- Need for privileged-access review, credential rotation, repository audit, and deployment-pipeline validation.
- Increased load from synthetic testing, transaction replay, manual screening, and heightened monitoring.

### Business, compliance, and regulatory impacts

- Possible processing of transactions without proper sanctions or AML checks.
- Payment delays, backlog, cut-off pressure, and customer or correspondent-bank concerns.
- Potential sanctions breach, suspicious-activity review, regulatory scrutiny, and remediation commitments.
- Reputational risk if the organization cannot clearly explain containment and lookback completeness.
- Internal audit and control assurance implications for change management, privileged access, and fail-safe design.

## 17. Facilitator Guide and Evaluation Rubric

### 17.1 Desired behaviors to observe

- Early recognition that zero alerts can signal silent control failure.

- Clear separation of confirmed facts, assumptions, and unknowns.
- Correct ownership between SOC technical containment, Crisis Cell enterprise decisions, Compliance risk assessment, Legal notification advice, and Operations execution.
- Risk-based payment controls rather than either doing nothing or stopping everything without criteria.
- Evidence preservation before broad restoration attempts.
- Regulator-ready communications that do not wait for perfect root cause.
- Recovery criteria based on independent validation, not optimism.

## 17.2 Common gaps to test for

- Overreliance on green system-health dashboards.
- Unclear authority to pause payments or force manual screening.
- Weak lookback methodology and inability to prove transaction-population completeness.
- SOC and Crisis Cell role confusion.
- No tested procedure for screening replay or synthetic control validation.
- Inadequate regulator update cadence or incomplete decision logs.
- Declaring recovery before privileged-access and telemetry integrity are verified.

## 17.3 Scoring rubric

Use a 1–5 scale for each capability: 1 = not demonstrated; 2 = weak; 3 = adequate with gaps; 4 = strong; 5 = exemplary and repeatable.

| Capability                          | What good looks like                                                                                                          | Low-score indicator                                                    | High-score indicator                                                               |
|-------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| Detection and validation            | Recognizes alert collapse as potential integrity failure; validates end-to-end execution; uses baselines and synthetic tests. | Treats issue as dashboard anomaly only; no independent validation.     | Confirms fail-open/fail-closed status quickly and escalates evidence.              |
| Governance and escalation           | Activates the right teams, severity, decision cadence, and decision log.                                                      | Unclear ownership; crisis cell and SOC responsibilities conflict.      | SOC owns technical containment; Crisis Cell owns enterprise/business decisions.    |
| Technical containment               | Preserves evidence, disables suspect access, freezes risky changes, validates telemetry, and protects logs.                   | Deletes/overwrites evidence; delays account containment.               | Balances containment with forensic preservation and business continuity.           |
| Compliance and transaction controls | Defines impacted populations, hold/queue criteria, manual screening, and retrospective replay.                                | Continues all payments without compensating controls or lookback plan. | Risk-based corridors, defensible lookback, and documented exceptions.              |
| Regulatory and legal communications | Builds regulator-ready fact pattern and notification decision record.                                                         | Waits for full root cause before considering notification.             | Provides timely known-facts/unknowns/update cadence with Legal/Compliance signoff. |
| Recovery assurance                  | Defines and tests safe restoration criteria before resuming normal processing.                                                | Restores based only on vendor/application statement.                   | Independent validation, known-good hash, replay results, monitoring confirmed.     |

| Capability      | What good looks like                                            | Low-score indicator                                    | High-score indicator                            |
|-----------------|-----------------------------------------------------------------|--------------------------------------------------------|-------------------------------------------------|
| Lessons learned | Converts gaps into owners, due dates, and control improvements. | Generic lessons without owners or measurable outcomes. | 30/60/90-day remediation plan with audit trail. |

## 18. Debrief, Lessons Learned, and Improvement Actions

### 18.1 Debrief headings

- Detection and validation of integrity failure.
- Severity assessment and escalation.
- Decision authority and crisis governance.
- Compensating controls and payment operations.
- Retrospective screening readiness and completeness.
- Evidence preservation and technical investigation.
- Regulatory, legal, and communications decision-making.
- Recovery criteria and assurance.
- Monitoring, fail-safe design, and long-term remediation.

### 18.2 Suggested after-action outputs

- Action register with owners, due dates, dependencies, and executive sponsor.
- Control improvement plan for rule integrity monitoring, alert-volume baselining, fail-open prevention, and synthetic screening tests.
- Privileged-access and change-management review for compliance systems.
- Regulator notification playbook validation, including sample initial update and follow-up templates.
- Test plan for transaction lookback, screening replay, exception triage, and evidence preservation.
- Governance update clarifying SOC, Compliance, Crisis Cell, Payment Operations, Legal, and Communications roles.

### 18.3 30/60/90-day improvement plan

| Timeframe  | Recommended improvement actions                                                                                                                                                                           |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 0–30 days  | Define alert-volume collapse detection; document transaction hold/queue criteria; update escalation paths; confirm regulator notification playbooks; inventory privileged roles for screening platforms.  |
| 31–60 days | Implement or enhance rule-hash attestation, synthetic screening tests, PAM controls, watchlist delta reconciliation, and dashboarding for screening integrity rather than availability only.              |
| 61–90 days | Run a technical validation drill for screening replay; perform a privileged-access recertification; test recovery from known-good rule baseline; audit evidence retention and change-control enforcement. |

## 19. MITRE ATT&CK Mapping

The mapping below ties ATT&CK techniques to scenario stages and inject evidence. Technique IDs should be aligned with the organization's internal ATT&CK version because the framework evolves over time. The scenario's strongest impact mapping remains Data Manipulation and Stored Data Manipulation; earlier lifecycle stages are included to address the explicit adversary pathway.

| Tactic                                                                | Technique                                              | ID                                                 | Scenario relevance                                                                                                                                         | Relevant inject(s)   |
|-----------------------------------------------------------------------|--------------------------------------------------------|----------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|
| Initial Access                                                        | Phishing: Spearphishing Link                           | T1566.002                                          | Credential capture for a compliance rules administrator or vendor-support account.                                                                         | Backstory / Inject 5 |
| Initial Access / Persistence                                          | External Remote Services                               | T1133                                              | Use of VPN, VDI, or externally reachable admin portal to access internal screening administration.                                                         | Inject 3             |
| Initial Access / Persistence / Privilege Escalation / Defense Evasion | Valid Accounts                                         | T1078; T1078.002/ T1078.004 as applicable          | Compromised domain or cloud account used to make changes through normal administrative paths.                                                              | Injects 3–5          |
| Persistence / Privilege Escalation                                    | Account Manipulation                                   | T1098; T1098.001/ T1098.003/ T1098.007 conditional | Temporary role, added credential, or group membership used to preserve access to rule deployment path.                                                     | Injects 3–5          |
| Execution                                                             | Command and Scripting Interpreter                      | T1059; T1059.001 conditional                       | Administrative scripts or automation jobs used to export or modify configuration packages.                                                                 | Inject 5             |
| Discovery                                                             | Account Discovery                                      | T1087                                              | Enumeration of accounts with screening-administration privileges.                                                                                          | Inject 3             |
| Discovery                                                             | Permission Groups Discovery                            | T1069                                              | Discovery of elevated groups, PAM roles, and release-approval permissions.                                                                                 | Inject 3             |
| Collection                                                            | Data from Information Repositories / Code Repositories | T1213; T1213.003 conditional                       | Access to internal documentation, rule repositories, or deployment packages to understand screening logic.                                                 | Inject 5             |
| Command and Control                                                   | Application Layer Protocol: Web Protocols              | T1071.001                                          | Encrypted HTTPS traffic used for remote control or outbound configuration export, blending with normal web activity.                                       | Inject 5             |
| Exfiltration                                                          | Exfiltration Over C2 Channel                           | T1041                                              | Limited export of configuration/rule metadata over existing communications channel; customer-data exfiltration is not assumed unless added by facilitator. | Inject 5             |



| Tactic                               | Technique                                 | ID                                        | Scenario relevance                                                                                                                                    | Relevant inject(s) |
|--------------------------------------|-------------------------------------------|-------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| Defense Evasion / Defense Impairment | Impair Defenses / Disable or Modify Tools | T1562 or current-version equivalent T1685 | Integrity monitors, alert thresholds, or log-forwarding jobs impaired to delay detection.                                                             | Injects 2–5        |
| Defense Evasion                      | Indicator Removal                         | T1070                                     | Selective deletion or alteration of evidence such as audit entries, command history, or job logs.                                                     | Inject 5           |
| Impact                               | Data Manipulation                         | T1565                                     | Manipulation of rules/reference data changes business outcomes and undermines compliance-control integrity.                                           | Injects 1–6        |
| Impact                               | Stored Data Manipulation                  | T1565.001                                 | Rules, watchlists, thresholds, or decision tables stored in the platform are altered.                                                                 | Injects 2–5        |
| Impact                               | Transmitted or Runtime Data Manipulation  | T1565.002 / T1565.003 conditional         | If the facilitator chooses a message-bus or runtime manipulation variant, screening requests or displayed outcomes are altered in transit or runtime. | Optional variant   |
| Impact                               | Service Stop                              | T1489 conditional                         | Containment may require stopping services or pausing payment flows; not the primary adversary objective.                                              | Injects 3–6        |

## 20. Source Mapping and References

### 20.1 Source mapping from uploaded scenario

The exercise content was derived from the uploaded STIX-based tabletop scenario and strengthened using the uploaded evaluation feedback. Key inherited elements include:

- Organization identity: banking organization subject to AML and sanctions-screening obligations.
- Infrastructure: AML and sanctions screening platform.
- Attack pattern: tamper with compliance screening data or rules to fail open.
- Incident: integrity failure in AML and sanctions screening.
- Inject note 1: screening alerts unexpectedly drop to zero.
- Inject note 2: retrospective review and regulator call.
- Courses of action: integrity monitoring and retrospective transaction screening / escalation procedure.

### 20.2 External references used for mapping and notification assumptions

- MITRE ATT&CK: Data Manipulation (T1565) and Stored Data Manipulation (T1565.001).
- MITRE ATT&CK: Valid Accounts (T1078), Account Discovery (T1087), Permission Groups Discovery (T1069), External Remote Services (T1133), Account Manipulation (T1098), Command and Scripting Interpreter (T1059), Data from Information Repositories (T1213), Application Layer Protocol: Web Protocols (T1071.001), Exfiltration Over C2 Channel (T1041), Indicator Removal (T1070), and Service Stop (T1489).
- OSFI Technology and Cyber Security Incident Reporting Advisory and incident report instructions.

- US federal banking agencies / FDIC Computer-Security Incident Notification rule and implementation guidance.
- European Banking Authority DORA major ICT-related incident reporting technical standards and classification criteria.
- FCA operational incident reporting guidance and policy statement.

**Legal note:** Regulatory timelines in this document are exercise assumptions, not legal advice. The facilitator should replace them with organization-specific obligations before delivery.

## 21. Ready-to-Use Opening Script

---

Today's exercise simulates a cyber-related integrity failure affecting the bank's AML and sanctions screening platform. During a period of normal transaction activity, alert volumes unexpectedly collapse. The system appears available, but screening outcomes may not be trustworthy.

Participants should respond using current roles, escalation paths, and procedures. The objective is to test how the organization detects, contains, escalates, communicates, and recovers from a silent but high-impact compliance-control failure with potential cyber, operational, and regulatory consequences.

Assumptions should be stated clearly. Please do not fight the scenario. Focus on realistic decisions, accountable ownership, evidence, and what would be needed to protect customers, the bank, and the integrity of the control environment.